

Graph-Augmented Hybrid RAG for Automated CVE-to-CWE Root-Cause Mapping

Sundarith Heng
Department of Computer Science
Angelo State University
San Angelo, TX, USA

Erdogan Dogdu
Department of Computer Science
Angelo State University
San Angelo, TX, USA

Roya Choupani
Department of Computer Science
Angelo State University
San Angelo, TX, USA

Abstract—Mapping Common Vulnerabilities and Exposures (CVE) records to root-cause Common Weakness Enumeration (CWE) categories supports vulnerability triage, remediation planning, and security analytics, but strong performance often depends on proprietary models or task-specific fine-tuning. We present a Graph-Augmented Hybrid RAG system that pairs 8B-class open-source language models with a multi-stage retrieval pipeline over two public knowledge sources: the NIST National Vulnerability Database and the official CWE corpus. The pipeline combines BM25 and dense hybrid retrieval, structured CVE-to-CWE bridge injection, weighted nearest-neighbor CWE voting, cross-encoder reranking, and Hypothetical Document Embedding (HyDE) candidate expansion with cross-encoder filtering. On the 1,000-query CTI-Bench RCM benchmark, a deterministic routed ensemble that assigns NVD-mapped CVEs to IBM Granite 4.1 8B and NVD-unmapped CVEs to Cisco Foundation-Sec-8B-Reasoning reaches 86.4% strict accuracy (864/1000). This surpasses the strongest published open-source specialist baseline of 75.6% by 10.8 percentage points and exceeds GPT-4 (72.0%), the published no-retrieval frontier anchor for this benchmark, by 14.4 percentage points. The result shows that carefully structured public retrieval can make small local models competitive with closed cybersecurity systems on CVE-to-CWE root-cause mapping, without fine-tuning the final-answer models.

Index Terms—cyber threat intelligence, CVE, CWE, retrieval-augmented generation, hybrid retrieval, vulnerability classification, root-cause mapping

I. INTRODUCTION

Mapping newly disclosed Common Vulnerabilities and Exposures (CVE) records to root-cause Common Weakness Enumeration (CWE) identifiers is a recurring task in cyber threat intelligence (CTI). The mapping determines how analysts group vulnerabilities, select mitigations, prioritize remediation, and connect newly disclosed flaws to existing weakness taxonomies. Errors in this step propagate into downstream analysis, so CVE-to-CWE mapping is a narrow but important target for automation.

Large proprietary language models can perform this mapping when given only the CVE description, but their use introduces deployment costs: paid API access, transmission of vulnerability data to a third party, and limited reproducibility. Security-specialized open models have narrowed the gap, reaching up to 75.6% on the CTI-Bench RCM benchmark [1], yet still fall short of closed security systems reporting around 85–86% [2], [3]. For reference, GPT-4—the published no-retrieval frontier anchor for this benchmark—scores 72.0% [4].

Local 7B–8B models without retrieval augmentation remain substantially weaker still.

This paper studies whether local 8B-class models can close that gap by reading public vulnerability knowledge at inference time. We build a graph-augmented hybrid retrieval-augmented generation (RAG) pipeline over two public sources: the National Vulnerability Database (NVD) CVE corpus and the official MITRE CWE corpus. The pipeline combines BM25 and dense retrieval, explicit CVE-to-CWE bridge injection, weighted nearest-neighbor voting, cross-encoder reranking, and HyDE candidate expansion with cross-encoder filtering. We then add a deterministic model router: NVD-mapped CVEs are sent to a RAG-specialized model, while NVD-unmapped CVEs are sent to a security reasoning model.

The central research question is: under the CTI-Bench single-answer protocol, how far can local open-source 8B-class models go when paired with a retrieval pipeline over public CVE and CWE data, and which retrieval stages contribute most to the final accuracy?

This work makes four contributions:

- We present a two-source graph-augmented hybrid RAG architecture for CVE-to-CWE root-cause mapping using only public NVD and CWE data.
- We introduce a mapped/unmapped execution split: an NVD bridge fast path for mapped CVEs and a multi-stage reasoning path for unmapped CVEs.
- We evaluate the pipeline on all 1,000 CTI-Bench RCM queries and report ablations for phrase selection, cross-encoder reranking, HyDE filtering, and k-NN confidence calibration.
- We show that a deterministic routed ensemble reaches 86.4% strict accuracy, surpassing the strongest published open-source specialist by 10.8 percentage points and exceeding GPT-4, the published no-retrieval CTI-Bench anchor, by 14.4 percentage points—all while running locally on commodity hardware.

II. BACKGROUND AND RELATED WORK

Prior work on automated CVE-to-CWE classification and RAG-based security analytics falls into three lines: general retrieval and reranking foundations, CVE-to-CWE classification methods, and security-tuned LLMs. We review each in turn.

A. Retrieval-Augmented Generation

Retrieval-Augmented Generation (RAG) combines a parametric generator with non-parametric retrieval over an external corpus [5]. This decoupling is central to our design: instead of fine-tuning the language model to memorize the CWE taxonomy, we expose authoritative CWE and CVE evidence at inference time. BM25 remains a strong sparse retrieval baseline for exact identifiers and rare terms [6], while dense bi-encoders such as Sentence-BERT and BGE capture semantic similarity [7], [8]. Prior ranking work motivates combining sparse and dense signals and reranking with a cross-encoder [9], [10]. We use this two-stage pattern to discriminate fine-grained CWE candidates whose definitions share most vocabulary.

HyDE retrieves against a generated hypothetical answer rather than the original query [11]. In our setting, the hypothesis is a short CWE-style weakness description produced from CVE prose. Because generated hypotheses can introduce noise, we score HyDE candidates against the original CVE description with a cross-encoder before adding them to context.

B. CVE-to-CWE Classification

CTI-Bench provides the evaluation protocol used in this paper: 1,000 CVE descriptions with manually curated CWE labels, evaluated by strict identifier match under a single-call LLM protocol [4]. ThreatZoom introduced an early neural CVE-to-CWE classifier using hierarchical CWE structure [12]. More recently, Mosievskiy fine-tuned RoBERTa-base on CVE-to-CWE pairs and reported 75.6% strict accuracy on CTI-Bench RCM [1]. Our approach differs from these classifiers by retrieving public CVE/CWE evidence at inference time rather than relying only on the CVE description.

Cybersecurity instruction tuning alone has not closed the gap on CTI-RCM. CyberPal.AI reports a best CTI-RCM score of 60.65% after full-parameter cybersecurity SFT [13]. AttackQA, though focused on ATT&CK question answering rather than CVE-to-CWE mapping, found that tuning the retrieval model contributed more than tuning the generator [14]. These results support a retrieval-first approach.

C. Security LLMs and Routed Models

Security-tuned LLMs provide important comparison points. Cisco’s Foundation-Sec models continue pre-training and reasoning tuning on cybersecurity corpora [15], [16]. Trend Micro’s Llama-Primus and WhiteRabbitNeo pursue similar cybersecurity adaptation [17], [18]. Closed systems such as Sec-Gemini and SecLM report strong CTI-RCM results but are not locally reproducible [2], [3]. IBM Granite 4.1 8B emphasizes RAG and tool-use behavior in its training mix [19].

The routed ensemble in this paper is motivated by evidence that RAG-oriented fine-tuning can trade off grounded extraction against general reasoning. Huang et al. [20] document catastrophic forgetting under RAG fine-tuning on Qwen2.5-7B-Instruct; Mallen et al. [21] show that retrieval and parametric memory dominate in different regimes. We use public

NVD mapping status as a deterministic routing signal: mapped CVEs are cases where retrieval has an authoritative answer, while unmapped CVEs require more abstractive CWE reasoning.

III. GRAPH-AUGMENTED HYBRID RAG

A. Knowledge Base

The knowledge base contains two sources. First, the official CWE XML corpus is chunked into weakness entries containing identifiers, names, descriptions, alternate terms, hierarchy information, and related explanatory text. Second, NVD CVE records are chunked from CNA and ADP containers. Structured NVD CWE assignments are extracted from the official NVD weakness fields. Textual mentions of CWE identifiers inside CVE prose are not treated as graph edges; only structured NVD fields are used for CVE-to-CWE bridges.

This produces approximately 332,000 chunks, including roughly 150,000 CVE records with structured CWE assignments. Each chunk has a sparse BM25 representation and a dense BGE-small embedding. A lightweight CVE-to-CWE index records whether each CVE has an NVD CWE mapping and is used both for bridge injection and for runtime routing.

B. Retrieval Pipeline

Given a CTI-Bench prompt, the system performs hybrid retrieval with equal BM25 and dense weights. The initial top- K pool uses $K = 8$. If the retrieved CVE chunk carries a structured NVD CWE assignment, the pipeline takes a fast path: the bridge-mapped CWE chunks are injected into context, competing CWE chunks are removed, and the final prompt is assembled without HyDE, k-NN fallback, or cross-encoder reranking.

If no structured bridge fires, the pipeline follows the unmapped reasoning path. HyDE first generates a short hypothetical weakness description from the CVE prose, retrieves additional CWE candidates against that hypothesis, and filters them with a BGE-Reranker-Base cross-encoder against the original prompt. The system then computes weighted votes from the five nearest mapped CVE neighbors. A vote is treated as authoritative only when its weighted share is at least 0.90 and its margin over the runner-up is at least 1.50; otherwise it remains a soft hint. Finally, all remaining CWE candidates are reranked with the cross-encoder before context assembly.

Figure 1 summarizes the two execution paths. Mapped CVEs follow a short evidence-injection path, while unmapped CVEs use candidate expansion, nearest-neighbor evidence, and reranking before the final answer call.

C. Routed LLM Ensemble

The final answer model is selected by public NVD mapping status. NVD-mapped CVEs are assigned to IBM Granite 4.1 8B, which is optimized for grounded RAG-style response behavior. NVD-unmapped CVEs are assigned to Cisco Foundation-Sec-8B-Reasoning, which is used as a specialist for taxonomy-reasoning cases where no authoritative NVD

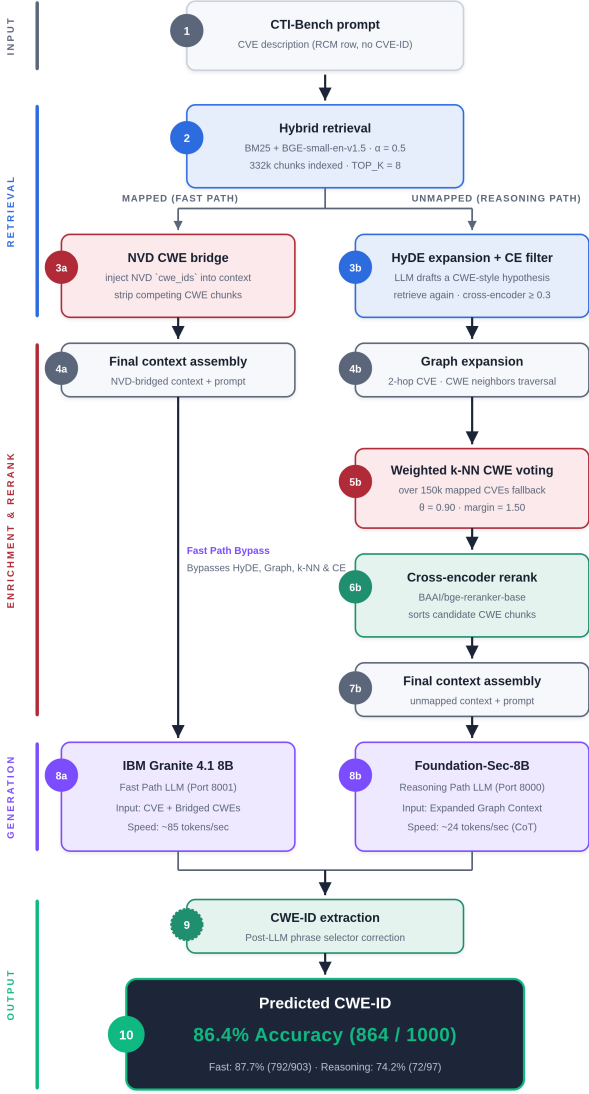


Fig. 1. Routed inference pipeline. NVD-mapped CVEs take a bridge-injection fast path and are routed to Granite 4.1 8B. NVD-unmapped CVEs use HyDE expansion, graph expansion, weighted k-NN voting, and cross-encoder reranking before routing to Foundation-Sec-8B-Reasoning.

bridge is available. The routing decision is deterministic and depends only on metadata available before inference.

This routing rule does not inspect CTI-Bench labels. It uses the same NVD mapping status that would be available for a newly disclosed CVE. The rule is nevertheless a limitation: its direction was selected after observing subset-specific behavior on this benchmark, so future validation on new splits is needed.

IV. EXPERIMENTAL SETUP

A. Benchmark and Metrics

We evaluate on the CTI-Bench CTI-RCM split [4]. The benchmark contains 1,000 CVE-to-CWE prompts and ground-truth CWE identifiers. We use each row’s Prompt field

directly and score by strict CWE identifier match. The benchmark divides naturally into 903 NVD-mapped CVEs and 97 NVD-unmapped CVEs according to the local NVD index.

B. Models

The single-model locked recipe uses Qwen2.5-7B-Instruct as the final answer model. Additional probes include Qwen3-8B, IBM Granite 4.1 8B, and Foundation-Sec-8B-Reasoning. The routed ensemble uses Granite for NVD-mapped final calls and Foundation-Sec for NVD-unmapped final calls. Retrieval-side components use BM25, BGE-small embeddings, and a BGE cross-encoder reranker; the final-answer models are not fine-tuned.

C. Protocol

The evaluation preserves the CTI-Bench final-answer protocol: one final LLM answer call per query at the configured default decoding settings. Retrieval-side HyDE calls are not final answer calls; they generate only hypothetical weakness text for candidate expansion. We report full-benchmark accuracy, mapped and unmapped subset accuracy, ablations of retrieval stages, and wall-clock runtime as a secondary engineering measure.

D. Reproducibility Controls

To preserve comparability with CTI-Bench, we use the benchmark prompt text unchanged and score only strict CWE identifier matches. Each reported condition is evaluated on the full 1,000-query split. Retrieval uses only public NVD and CWE sources, and CVE-to-CWE graph edges are constructed only from structured NVD weakness fields rather than textual CWE mentions in CVE prose. The final-answer models are used without fine-tuning; ablations change retrieval components while holding the benchmark prompts, scoring script, and final-answer protocol fixed.

All experiments run on a single workstation with two NVIDIA RTX 4090 GPUs (24 GB each), serving Granite 4.1 8B (port 8001) and Foundation-Sec-8B-Reasoning (port 8000) via vLLM 0.19.1 with prefix caching. Retrieval-side components (BGE-small bi-encoder, BGE-Reranker-Base cross-encoder, BM25 index) run on CPU. The full 1,000-query routed evaluation completes in approximately 19 minutes with three worker processes. Exact model identifiers, prompts, hyperparameters, and the evaluation harness are released with the paper; verbatim prompt templates are provided in Appendix A.

E. Data-Leakage Considerations

We separately address two leakage concerns. First, retrieval contents: the retriever indexes 1,450 public CWE entries from the official MITRE corpus and approximately 150,000 historical NVD CVE records. CWE entries themselves do not contain CVE-to-CWE labels, so retrieving a CWE description cannot expose the CTI-Bench gold mapping. The CVE corpus does carry NVD’s own structured CWE assignment, which is the signal the bridge fast path uses; however, on 94/136 routed-run failures (Section V-E) the CTI-Bench gold label disagrees with

NVD’s assignment, and our system follows NVD’s structured field rather than the CTI-Bench label. The published-bridge fast path therefore does not “leak” CTI-Bench gold answers; it provides whatever NVD curators recorded at disclosure time. Second, language-model pre-training: Foundation-Sec-8B-Reasoning and Granite 4.1 8B were trained before this work and may have seen public CVE descriptions during pre-training; CTI-Bench was published in 2024 [4], and prior CTI-Bench papers report the same risk for GPT-4 and Llama-3 baselines. We do not fine-tune the final-answer models on any CTI-Bench data and follow the published single-call protocol unchanged.

V. RESULTS

We evaluate the locked pipeline on the full 1,000-query CTI-Bench CTI-RCM split and compare it against published CTI-RCM baselines. The central question for this section is whether a local retrieval-grounded system can close the gap between open models and closed, security-tuned systems under the same strict exact-match metric. Figure 2 is included to make that comparison visually explicit: it places our routed result on the same 1,000-query scale as prior CTI-Bench RCM systems, colors methods by access model, and anchors the comparison with GPT-4’s published no-retrieval baseline.

The visual separation in Figure 2 shows three regimes. General no-retrieval LLM baselines range from 44.7% to 72.0%, security-specialized open models and task-specific classifiers reach 67.8%–75.6%, and the routed RAG system moves the open local setting to 86.4%. This is why we report both the figure and the numeric table: the figure shows the scale of the gap closure, while Table I records exact values and sources for reproducibility.

The margin over the strongest published open-source baseline is also larger than a small leaderboard fluctuation: our 86.4% routed result is above Mosievskiy’s reported 95% confidence interval for RoBERTa-base on CTI-Bench RCM (72.8%–78.2%) [1].

A. Ablation Study

Table II isolates the contribution of each retrieval stage. The baseline already reaches 84.3% because NVD bridge injection solves many mapped CVEs. The largest unmapped gain comes from the official CWE phrase selector, which raises unmapped accuracy from 62.9% to 70.1%. Cross-encoder reranking adds two unmapped cases. HyDE with cross-encoder filtering improves the mapped subset. Tightening k-NN confidence recovers two additional unmapped cases by preventing incorrect high-confidence votes from stripping the correct CWE.

Figure 3 visualizes the same progression. The full-benchmark bars move modestly because the mapped subset is already strong, while the unmapped bars show where the retrieval stages do most of their work.

B. Routed Ensemble

Table III reports two retrieval-only baselines that skip the LLM entirely and three LLM-augmented configurations. Pure

hybrid retrieval (BM25 + BGE) followed by selecting the highest-ranked CWE chunk reaches only 33.2%, confirming that surface-level lexical or dense similarity is insufficient on its own. Adding the structured NVD bridge for mapped CVEs—still without any LLM call—raises mapped accuracy to 87.8%, almost identical to the routed system’s 87.7% mapped accuracy. This indicates that the LLM contributes essentially no additional mapped-CVE accuracy beyond the public NVD structured field, and the mapped-subset gains we report are best understood as “structured retrieval as lookup” rather than reasoning. On the 97 NVD-unmapped CVEs, retrieval-only stays at 27.8%; the LLM-augmented pipeline raises this to 72–74%, accounting for almost all of the LLM’s measurable contribution.

Among LLM-augmented configurations, replacing Qwen2.5-7B with Qwen3-8B improves the single-model recipe from 85.1% to 85.6%, and the routed Granite/Foundation-Sec ensemble reaches 86.4%. A Foundation-Sec-only single-model configuration evaluated over two full-benchmark runs reaches $87.4 \pm 0.14\%$. A McNemar paired-prediction test between the routed configuration and Foundation-Sec-only (Section V-F) gives $p = 0.082$, indicating the two configurations are statistically indistinguishable on this benchmark; we therefore report them as two near-equivalent operating points rather than a single dominant system.

C. Unmapped Specialist Search

The unmapped subset measures taxonomy reasoning rather than simple lookup. Table IV summarizes model probes on the 97 NVD-unmapped examples. Foundation-Sec-8B-Reasoning is the best observed specialist, but its one-case margin over Qwen3-8B is small. Larger general models and several cybersecurity-tuned models underperform, suggesting that the remaining errors are dominated by fine-grained CWE boundary decisions rather than broad cybersecurity understanding.

D. Per-CWE Accuracy Breakdown

Figure 4 reports strict accuracy on the 20 most-frequent gold CWEs in CTI-Bench RCM, comparing the routed ensemble against the Foundation-Sec-only single-model configuration. The two systems are within ± 5 percentage points on most CWEs, with the largest gaps appearing on CWE-787 (Out-of-bounds Write), CWE-119 (Improper Memory Restriction), and CWE-121 (Stack-based Buffer Overflow). Both systems are near-perfect on web-application CWEs (CWE-79 XSS, CWE-89 SQLi, CWE-352 CSRF, CWE-918 SSRF, CWE-434 unrestricted upload, CWE-502 deserialization) and both struggle on memory-corruption CWEs that share heavy vocabulary overlap (CWE-787, CWE-120, CWE-119). The per-CWE pattern is consistent with the failure-mode typology in Section V-E: residual errors cluster on CWEs whose definitions are taxonomically adjacent.

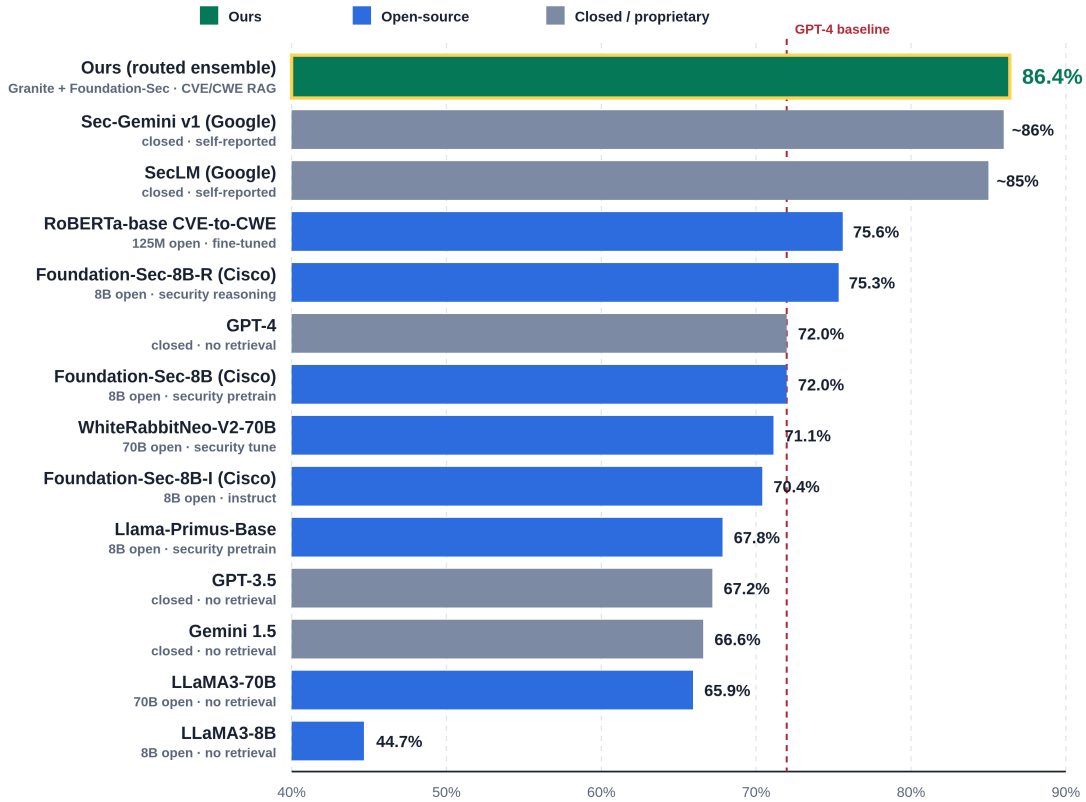


Fig. 2. Combined CTI-Bench RCM strict-accuracy leaderboard. The dashed line marks GPT-4’s published no-retrieval baseline; the routed ensemble is the reported result for this work and shows how retrieval plus deterministic routing closes the gap between open local systems and closed security-tuned systems. Proprietary frontier baselines are from CTI-Bench, closed-source security-tuned scores are self-reported by Google, and open-source comparison points are from published model papers and model cards.

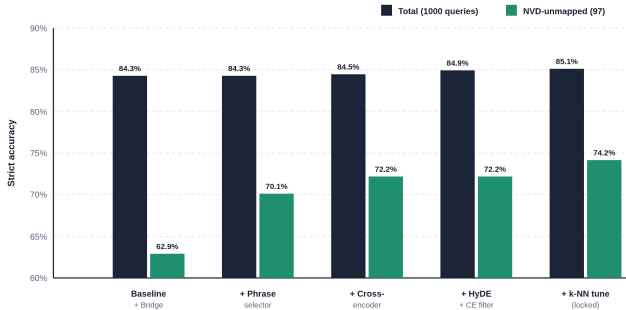


Fig. 3. CTI-RCM strict accuracy by pipeline stage. Dark bars show full-benchmark accuracy; green bars show accuracy on the 97 NVD-unmapped CVEs.

E. Failure-Mode Typology

We classified all 136 routed-run failures by the taxonomic relationship between the predicted CWE and the CTI-Bench gold CWE, walking the official CWE parent-child graph. Table V summarizes the result. Four out of five failures (110/136, 80.9%) are taxonomically close—predicted CWE is a parent, child, or sibling of gold—meaning the model is

reasoning about the right weakness family but selects a different abstraction level. Only 19.1% of failures are in unrelated CWE subtrees, and just two cases produce unparseable output.

A second analysis tracks how often NVD’s own structured CWE assignment differs from the CTI-Bench gold label on the failing CVEs: this is the case for 94/136 (69.1%) of failures. Many “errors” are therefore CWE assignments that are defensible against NVD’s own record but counted wrong under the CTI-Bench gold. We surface this as evidence that the residual error band partly reflects taxonomic disagreement between NVD and CTI-Bench curators rather than purely model error, and we report the strict CTI-Bench metric without modification to preserve comparability with prior work.

These categories motivate the retrieval-focused directions described in Section VI-E.

F. Runtime and Latency

Table VI reports per-stage wall-clock for the full 1,000-query routed run. Mean per-query latency is 3.41 s with three workers; total wall-clock is approximately 19 minutes including model startup. Mapped CVEs are fast (2.77 s mean) because the NVD bridge fast path skips HyDE, k-NN voting, and cross-encoder reranking. Unmapped CVEs

TABLE I
CTI-BENCH RCM LEADERBOARD. [†]SCORE IS SELF-REPORTED; NOT INDEPENDENTLY EVALUATED ON THE PUBLIC SPLIT.

Model	Params	Type	CTI-RCM	Source
Ours (routed ensemble)	8B	open	86.4%	this work
Sec-Gemini v1 (Google) [†]	—	closed	~86%	[2]
SecLM (Google) [†]	—	closed	~85%	[3]
RoBERTa-base CVE-to-CWE	125M	open	75.6%	[1]
Foundation-Sec-8B-R (Cisco)	8B	open	75.3%	[16]
GPT-4	~1.7T	closed	72.0%	[4]
Foundation-Sec-8B (Cisco)	8B	open	72.0%	[15]
WhiteRabbitNeo-V2-70B	70B	open	71.1%	[15]
Foundation-Sec-8B-I (Cisco)	8B	open	70.4%	[16]
Llama-Primus-Base (Trend Micro)	8B	open	67.8%	[17]
GPT-3.5	~175B	closed	67.2%	[4]
Gemini 1.5	—	closed	66.6%	[4]
LLaMA3-70B	70B	open	65.9%	[4]
CyberPal-Llama-3-8B	8B	open	60.7%	[13]
LLaMA3-8B	8B	open	44.7%	[4]

TABLE II
ABLATION OF RETRIEVAL-PIPELINE STAGES ON THE 1,000-QUERY CTI-RCM EVALUATION. VALUES ARE STRICT-MATCH ACCURACY (%) ON SINGLE FULL-BENCHMARK RUNS.

Configuration	Total (%)	Mapped (%)	Unmapped (%)
Hybrid + bridge (baseline)	84.3	86.6	62.9
+ Phrase selector	84.3	85.8	70.1
+ Cross-encoder rerank	84.5	85.8	72.2
+ HyDE + CE filter	84.9	86.3	72.2
+ Tightened k-NN ($\theta = 0.90$, margin 1.50)	85.1	86.3	74.2

TABLE III
FINAL CTI-RCM RESULTS BREAKDOWN. VALUES ARE STRICT-MATCH ACCURACY (%); $\pm\sigma$ REPORTED WHERE MULTIPLE RUNS ARE AVAILABLE (N=2). RETRIEVAL-ONLY BASELINES DO NOT INVOKE THE LLM.

Configuration	Total (%)	Mapped (%)	Unmapped (%)
Pure hybrid retrieval, top-1 CWE (no LLM, no bridge)	33.2	33.8	27.8
Hybrid + NVD bridge, top-1 CWE (no LLM)	82.0	87.8	27.8
Single-model locked recipe (Qwen2.5-7B)	85.1	86.3	74.2
+ Qwen3-8B model swap	85.6	86.8	74.2
Routed ensemble (Granite + Foundation-Sec)	86.4	87.7	74.2
Foundation-Sec-only (single model, n=2)	87.4 $\pm$ 0.14	89.1 $\pm$ 0.08	71.6 $\pm$ 0.78

are $3.4\times$ slower (9.42 s mean) because they execute the full retrieval pipeline plus HyDE and incur a longer final-answer call on Foundation-Sec-8B-Reasoning. Across all stages, the final LLM answer call dominates runtime (2.92 s mean, 85.6% of total per-query time).

A McNemar paired-prediction test on the per-item correctness vectors of the routed configuration and a Foundation-Sec-only single-model configuration ($n = 1,000$, same CVE IDs) yields $\chi^2 = 3.03$, $p = 0.082$, indicating no statistically significant difference between the two systems. We report the routed configuration as one of two near-equivalent operating points, not as a strictly dominant configuration.

VI. DISCUSSION AND LIMITATIONS

A. Two Regimes: Retrieval-as-Lookup vs. Retrieval-plus-Reasoning

The retrieval-only baselines in Table III reveal that the system operates in two distinct accuracy regimes. On the 903 NVD-mapped CVEs, the LLM-free hybrid + NVD bridge configuration reaches 87.8%, statistically indistinguishable from the full routed pipeline’s 87.7%. The mapped-subset contribution is therefore best characterized as “retrieval-as-lookup”: public structured NVD evidence resolves the question, and the LLM serves to format the answer rather than reason about it. On the 97 NVD-unmapped CVEs, retrieval-only stays at 27.8% and the LLM-augmented pipeline lifts this to 71–74%, accounting for a 43–46 percentage-point gap that is entirely

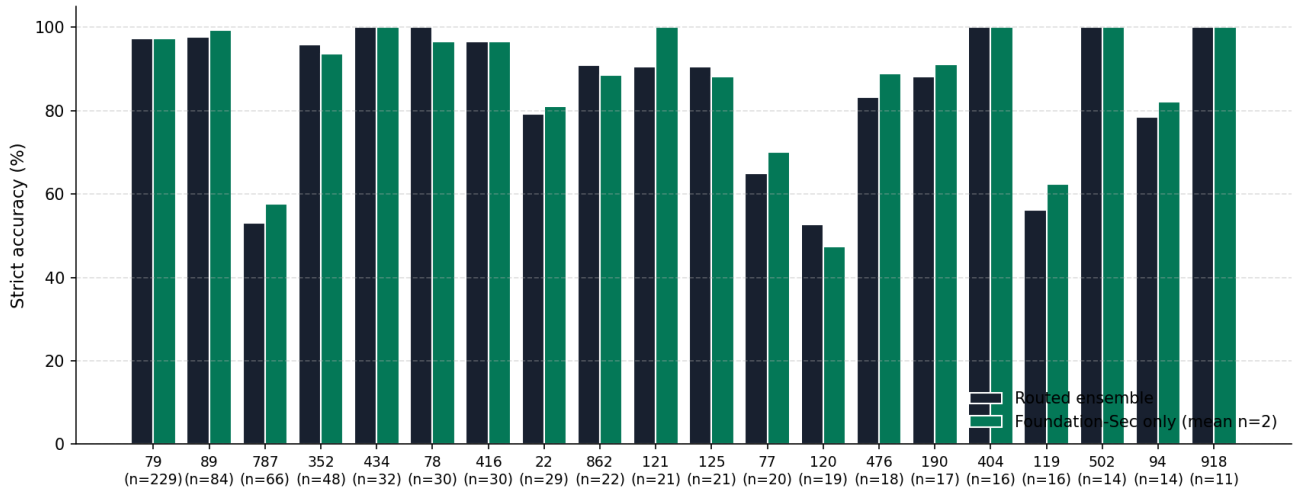


Fig. 4. Per-CWE strict accuracy on the 20 most-frequent CTI-Bench RCM CWEs (n = sample count per CWE). Dark bars: routed ensemble (single run); green bars: Foundation-Sec-only (mean of 2 runs).

TABLE IV
NVD-UNMAPIED SPECIALIST SEARCH.

Model	Score	Runs	Role
Foundation-Sec-8B-Reasoning	73/97	2	selected
Qwen3-8B + /no_think	72/97	2	near tie
Qwen3-14B-AWQ	69/97	1	not selected
Qwen2.5-14B-AWQ	69/97	1	not selected
WhiteRabbitNeo-2-8B	68/97	1	not selected
Qwen3.5-9B-AWQ	67/97	1	not selected
Gemma 4 E4B non-thinking	67/97	1	not selected
RedSage-Qwen3-8B-Ins	63/97	1	not selected
Llama-Primus-Base	59/97	1	not selected

TABLE V
FAILURE-MODE TYPOLOGY ON THE 136 ERRORS FROM THE 1,000-QUERY ROUTED RUN. “NVD-DISAGREES” FLAGS CASES WHERE NVD’S OWN STRUCTURED CWE ASSIGNMENT DIFFERS FROM THE CTI-BENCH GOLD LABEL.

Predicted vs. gold	Count	%
Child / descendant of gold (too specific)	59	43.4%
Sibling, shared ancestor	33	24.3%
Distant (different subtree)	26	19.1%
Parent / ancestor of gold (too abstract)	16	11.8%
No CWE parseable in answer	2	1.5%
NVD-disagrees-with-gold (cross-cutting flag)	94	69.1%

attributable to the LLM and the retrieval refinements (HyDE, k-NN voting, cross-encoder reranking) feeding it. The ablation table corroborates this split: retrieval-side reordering improves unmapped accuracy from 61/97 to 72/97, while prompt-heavy and override-heavy mechanisms tested during development did not provide stable gains.

TABLE VI
PER-STAGE WALL-CLOCK FOR THE 1,000-QUERY ROUTED RUN, AVERAGED OVER 3 WORKER PROCESSES. MAPPED CVEs SKIP HyDE / K-NN / CROSS-ENCODER VIA THE NVD-BRIDGE FAST PATH.

Stage	All (s)	Mapped (s)	Unmapped (s)
Initial hybrid retrieval	0.12	0.12	0.13
HyDE (LLM + retrieve + CE filter)	0.27	0.03	2.50
Graph + k-NN voting	0.02	0.00	0.20
Cross-encoder rerank	0.08	0.01	0.76
Final LLM answer	2.92	2.61	5.83
Total per query	3.41	2.77	9.42

B. Why Routing Helps

The mapped and unmapped subsets stress different model behaviors. Mapped CVEs are primarily grounded extraction problems: the system finds the matching CVE chunk and injects NVD’s structured CWE assignment. Granite is well suited to this path because it is optimized for RAG-like grounded response behavior. Unmapped CVEs lack an authoritative bridge and require a taxonomic classification decision from prose; Foundation-Sec and Qwen3 are stronger on that reasoning-heavy subset. This is consistent with prior work on RAG fine-tuning and the distinction between retrieval-backed and parametric-memory-backed answers [20], [21].

C. Validity and Limitations

The comparison to GPT-4 should be interpreted as a deployment comparison, not a raw model-capability comparison. GPT-4 in CTI-Bench had no retrieval over NVD or CWE, while our system has access to public data that analysts normally use. The mapped subset is therefore partly RAG-as-lookup. The unmapped subset is the stricter reasoning test, where the system achieves 74.2%.

The routing rule is deterministic and uses only public NVD mapping status, but the decision to send mapped CVEs to Granite and unmapped CVEs to Foundation-Sec was selected after observing subset-specific model behavior on this benchmark. A future CTI-Bench split or a held-out CVE set is needed to validate the router without this post-hoc element. Finally, the corpus is intentionally restricted to CVE and CWE sources for CTI-RCM; broader CTI tasks may require adding ATT&CK, CAPEC, and other threat-intelligence sources.

This work uses only public NVD CVE records, public CWE definitions, and public benchmark prompts. It does not generate exploit code, disclose previously unknown vulnerabilities, or involve human subjects. Outputs should be treated as analyst decision-support recommendations, not authoritative vulnerability assignments, since incorrect CWE mappings can misdirect remediation.

D. Non-Adopted Alternatives

Several plausible alternatives regressed. T-RAFT LLM fine-tuning on CVE-to-CWE examples reduced full-benchmark accuracy by roughly nine cases, largely because the model emitted verbose reasoning preambles where terse CWE answers had previously succeeded. BGE-small contrastive fine-tuning regressed by 29 cases because it shifted embeddings away from CVE self-retrieval and used false-negative hard negatives. A cross-encoder LoRA attempt also regressed after filtering out many of the hardest examples. Larger cross-encoders and self-consistency did not provide comparable, protocol-preserving gains.

E. Future Work

Four directions address the remaining failure modes. (1) Domain-adapted retrieval: a cross-encoder fine-tuning recipe with stronger false-negative filtering [22] may reduce context misses, which account for approximately 60% of residual failures. (2) Catastrophic-forgetting-aware fine-tuning: distillation-based RAG fine-tuning [20] may improve near-miss failures without regressing easy cases. (3) Confidence-weighted routing: replacing the binary NVD-status router with a continuous signal combining bridge strength, k-NN margin, and cross-encoder score gap may improve borderline cases. (4) Generalization: the same two-source architecture should be evaluated on other CTI-Bench tasks to test whether the retrieval design extends beyond root-cause mapping.

VII. CONCLUSION

This paper presented a Graph-Augmented Hybrid RAG system for CVE-to-CWE root-cause mapping. Using only public NVD and CWE data, the routed Granite/Foundation-Sec ensemble reaches 86.4% strict accuracy on CTI-Bench RCM. The result exceeds the published GPT-4 no-retrieval baseline and the strongest open-source published baseline while remaining local and reproducible.

The main lesson is that careful retrieval design can make small local models competitive on a cybersecurity taxonomy task. Bridge injection solves many NVD-mapped cases, while

phrase selection, cross-encoder reranking, HyDE filtering, and calibrated k-NN voting improve the harder unmapped cases. Routing adds a final gain by matching model behavior to the mapped/unmapped structure of the task.

APPENDIX A PROMPT TEMPLATES

A. HyDE Hypothesis Prompt (Unmapped Path)

Issued to the routed HyDE endpoint to generate a 2-sentence weakness description that feeds an additional CWE-chunk retrieval. The hypothesis text is used only for retrieval; it is not shown to the final-answer model.

Given the CVE description below, write a 2-sentence description of the underlying software weakness in the abstract style of a MITRE CWE (Common Weakness Enumeration) entry. Focus on the general weakness category (for example 'improper validation of input', 'exposure of a resource to an unintended sphere', 'missing authorization for a sensitive operation', 'incorrect calculation of buffer size'). Avoid mentioning the specific product, version, or exploit. Do not include CWE IDs.
CVE Description: {query}
Weakness description:

B. Final Answer Prompt

Issued once per query to the routed final-answer endpoint (Granite for mapped, Foundation-Sec for unmapped). Rule blocks marked {cve_rule}, {hierarchy_rule}, {listwise_rule}, and {eval_rule} are populated from per-query routing state (e.g., when an NVD bridge fires, {cve_rule} forces the model to emit only the bridge-injected CWE).

You are a Cyber Threat Intelligence expert. Answer the question based ONLY on the provided context.
CRITICAL RULES: 1. If the question asks for "Detection" or "How to detect", use the "Detection Strategy" or "Analytics" chunks. 2. Do NOT use the "Mitigations" section to answer detection questions. 3. If an answer cannot be found in the context, say "I don't have enough information in my database." 4. Answer ONLY what is asked. Be concise and technical. 5. Do NOT invent, infer, or fabricate technique IDs, group names, or relationships not in the context. 6. Answer ONLY the current question. 7. The [TYPE IDENTIFIER -- NAME] header in each context block is authoritative; never rename or re-identify based on training knowledge. 8. Do not add shell commands, scripts, vendor names, or tool recommendations that are not verbatim in the context.

{cve_rule} {hierarchy_rule} {listwise_rule} {eval_rule}
Context: {context}

QUESTION: {question}

ANSWER:

REFERENCES

- [1] N. Mosievskiy, “Fine-tuning roberta for cve-to-cwe classification: A 125m parameter model competitive with llms,” <https://arxiv.org/abs/2603.14911>, 2026, *arXiv preprint*.
- [2] Google, “Google announces sec-gemini v1, a new experimental cybersecurity model,” <https://security.googleblog.com/2025/04/google-launches-sec-gemini-v1-new.html>, 2025, *Google Online Security Blog* (April 4, 2025).
- [3] —, “Fueling ai innovation in secops products: The secLM platform and sec-gemini research pipeline,” <https://www.googlecloudcommunity.com/gc/Community-Blog/Fueling-AI-Innovation-in-SecOps-Products-The-SecLM-Platform-and/ba-p/913254>, 2025, *Google Cloud Community Blog*.
- [4] M. T. Alam, D. Bhusal, Y. Park, and N. Rastogi, “Ctibench: A benchmark for evaluating llms in cyber threat intelligence,” <https://arxiv.org/abs/2406.07599>, 2024, *NeurIPS 2024*.
- [5] P. Lewis, E. Perez, A. Piktus *et al.*, “Retrieval-augmented generation for knowledge-intensive nlp tasks,” <https://arxiv.org/abs/2005.11401>, 2020, *NeurIPS 2020*.
- [6] S. Robertson and H. Zaragoza, “The probabilistic relevance framework: Bm25 and beyond,” <https://doi.org/10.1561/15000000019>, 2009, *Foundations and Trends in Information Retrieval*, 3(4), 333–389.
- [7] N. Reimers and I. Gurevych, “Sentence-bert: Sentence embeddings using siamese bert-networks,” <https://arxiv.org/abs/1908.10084>, 2019, *EMNLP 2019*.
- [8] S. Xiao, Z. Liu, P. Zhang, and N. Muennighoff, “C-pack: Packaged resources to advance general chinese embedding (bge),” <https://arxiv.org/abs/2309.07597>, 2024, *SIGIR 2024*.
- [9] J. Lin, R. Nogueira, and A. Yates, “Pretrained transformers for text ranking: Bert and beyond,” <https://arxiv.org/abs/2010.06467>, 2021, *Synthesis Lectures on Human Language Technologies*.
- [10] R. Nogueira and K. Cho, “Passage re-ranking with bert,” <https://arxiv.org/abs/1901.04085>, 2019, *arXiv preprint*.
- [11] L. Gao, X. Ma, J. Lin, and J. Callan, “Precise zero-shot dense retrieval without relevance labels (hyde),” <https://arxiv.org/abs/2212.10496>, 2022, *arXiv preprint*.
- [12] E. Aghaei, X. Niu, W. Shadid, and E. Al-Shaer, “Threatzoom: Cve2cwe using hierarchical neural network,” <https://arxiv.org/abs/2009.11501>, 2020, *SecureComm 2020*.
- [13] M. Levi, Y. Allouche, D. Ohayon, and A. Puzanov, “Cyberpal.ai: Empowering llms with expert-driven cybersecurity instructions,” <https://arxiv.org/abs/2408.09304>, 2024, *arXiv preprint* (IBM Research / Ben-Gurion University).
- [14] V. B. Krishna, “Attackqa: Development and adoption of a dataset for assisting cybersecurity operations using fine-tuned and open-source llms,” <https://arxiv.org/abs/2411.01073>, 2024, *arXiv preprint* (SambaNova Systems).
- [15] P. Kassinik *et al.*, “Llama-3.1-foundationai-securityllm-base-8b technical report,” <https://arxiv.org/abs/2504.21039>, 2025, *arXiv preprint* (Cisco Foundation AI).
- [16] A. Yang *et al.*, “Llama-3.1-foundationai-securityllm-reasoning-8b technical report,” <https://arxiv.org/abs/2601.21051>, 2026, *arXiv preprint* (Cisco Foundation AI).
- [17] Y.-C. Yu *et al.*, “Primus: A pioneering collection of open-source datasets for cybersecurity llm training,” <https://arxiv.org/abs/2502.11191>, 2025, *arXiv preprint* (Trend Micro).
- [18] WhiteRabbitNeo, “Whiterabbitneo-v2 cybersecurity llm (llama-3.1 8b / 70b),” <https://huggingface.co/WhiteRabbitNeo>, 2024, *Hugging Face model card*.
- [19] IBM Granite Team, “Granite 4.1 model family,” <https://huggingface.co/blog/ibm-granite/granite-4-1>, 2026, *HuggingFace Blog / IBM Research*.
- [20] Y. Huang, R. Zhang, Q. Wang *et al.*, “Selfaug: Mitigating catastrophic forgetting in rag via distribution self-alignment,” <https://arxiv.org/abs/2509.03934>, 2025, *arXiv preprint*.
- [21] A. Mallen, A. Asai, V. Zhong *et al.*, “When not to trust language models: Investigating effectiveness of parametric and non-parametric memories,” <https://arxiv.org/abs/2212.10511>, 2022, *arXiv preprint* (UW / AI2).
- [22] G. Moreira, R. Osmulski, M. Xu *et al.*, “Nv-retriever: Improving text embedding models with effective hard-negative mining,” <https://arxiv.org/abs/2407.15831>, 2024, *arXiv preprint*.